SOCIAL ENGINEERING & PHISHING CAMPAIGN SIMULATION FOR GRC PROFESSIONALS

Prepared by: GRC Audit Team
Date: 4 November 2026
Tool Used: GoPhish
Operating System: Kali Linux
Email Testing Service: Mailtrap
Campaign Name: Q3 GRC Phishing Simulation

1. INTRODUCTION

Cybersecurity risks extend beyond technical vulnerabilities. Human behaviour is also a significant factor in an organization's security posture, as attackers frequently exploit human trust, curiosity and lack of security awareness through social engineering attacks.

This practical exercise focused on phishing simulation using GoPhish to understand how phishing campaigns operate and how organizations can assess their exposure to social engineering attacks.

The exercise also examined the role of Governance, Risk and Compliance (GRC) professionals in identifying human-related security risks, evaluating existing security controls and recommending improvements.

2. OBJECTIVES

The objectives of this exercise were to:

1. Understand the mechanics of social engineering and phishing attacks.
2. Install and configure the GoPhish phishing simulation framework.
3. Configure an SMTP sending profile using Mailtrap.
4. Create an email template and a simulated landing page.
5. Conduct a controlled phishing simulation using a test environment.
6. Analyze campaign results and calculate relevant risk metrics.
7. Identify potential weaknesses in security awareness and technical controls.
8. Develop recommendations to improve organizational security.

3. LAB ENVIRONMENT AND TOOLS

The following tools and components were used:

Kali Linux	Operating system used for the practical exercise
GoPhish	Open-source phishing simulation framework
Mailtrap	Email testing and SMTP service
Mozilla Firefox	Accessing the GoPhish administration dashboard
Test mailbox	Simulated recipient environment
Local landing page	Simulated destination for the campaign

The exercise was conducted in a controlled environment using a test recipient. No organizational employees were targeted.

4. IMPLEMENTATION AND CONFIGURATION

Phase 1: Setup and Preparation

Step 1: Installation of GoPhish

GoPhish was downloaded and installed on Kali Linux.

The following commands were executed:

```
sudo apt update
sudo apt install wget unzip -y
```

The GoPhish archive was downloaded and extracted:

```
wget https://github.com/gophish/gophish/releases/download/v0.12.1/gophish-v0.12.1-linux-64bit.zip

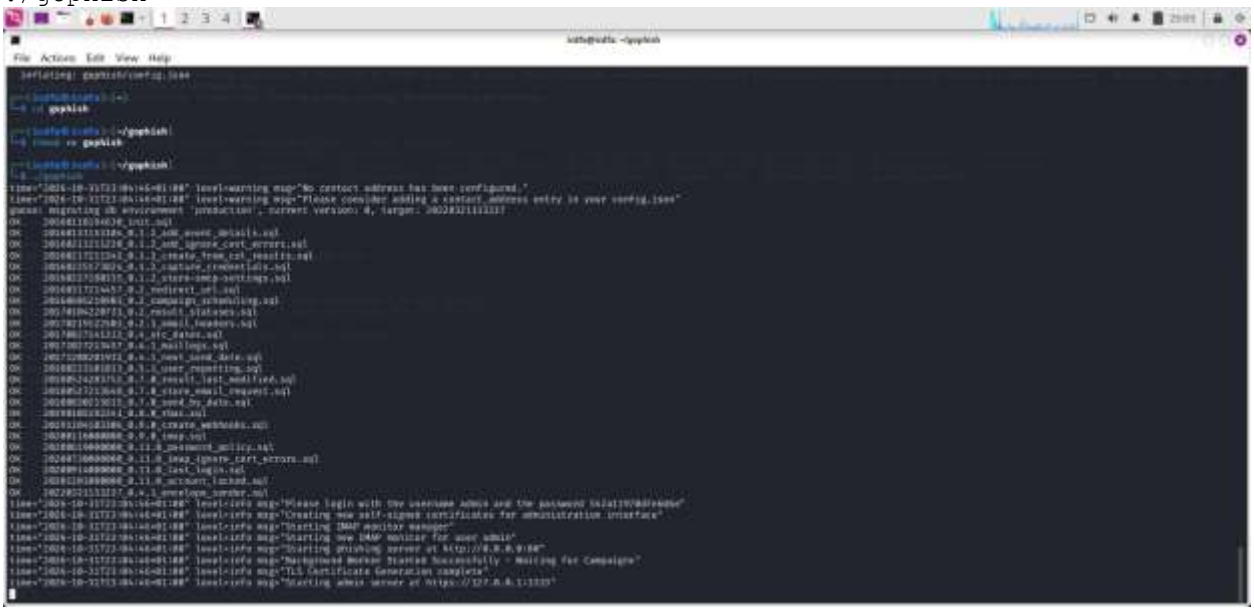
unzip gophish-v0.12.1-linux-64bit.zip -d gophish/

cd gophish/

chmod +x gophish
```

GoPhish was started using:

```
./gophish
```



The administration interface was accessed through:

```
https://127.0.0.1:3333
```

The application successfully started, and the GoPhish administration dashboard became accessible through Firefox.

Step 2: SMTP Configuration Using Mailtrap

Mailtrap was configured to provide a safe environment for testing outgoing emails.

The following configuration was performed:

1. Created and accessed a Mailtrap account.
2. Opened the Email Testing sandbox.
3. Retrieved the SMTP configuration details.
4. Created a new sending profile in GoPhish.
5. Entered the Mailtrap SMTP host, port, username and password.
6. Saved the sending profile.

The sending profile was named **MailtrapTest**.

Mailtrap successfully captured the test messages, confirming that the SMTP configuration was functioning.

Step 3: Landing Page Configuration

A landing page named **GRC Security Awareness Test** was configured in GoPhish.

A simulated landing page was used instead of collecting real login credentials.

The page served as the destination for the test email link.

The exercise focused on measuring campaign interactions without collecting genuine user passwords.

Step 4: Email Template Creation

An email template named **VPN Password Reset Required** was created.

Email Subject:

Action Required: Your VPN Password Expires in 24 Hours

The template used GoPhish personalization variables, including:

- `{{.FirstName}}` – Personalizes the recipient's first name.
- `{{.URL}}` – Generates the campaign tracking link.

The email represented a simulated VPN password-expiry notification.

Step 5: Target Group Configuration

A test group named **Lab Test Group** was created under Users & Groups.

Twenty test recipient was added to the group.

Phase 2: Campaign Execution

Step 6: Launching the Campaign

A campaign named **Q3 GRC Phishing Simulation** was created.

The following components were selected:

Campaign Name	Q3 GRC Phishing Simulation
Email Template	VPN Password Reset Required
Landing Page	GRC Security Awareness Test
Sending Profile	MailtrapTest
Target Group	Lab Test Group

The campaign was launched, and GoPhish successfully recorded the email-sending event.

Phase 3: Monitoring and Analysis

Step 7: Campaign Results

The campaign results were examined through the GoPhish campaign dashboard.

The campaign recorded the following actual results:

Metric	Recorded Result
Emails Sent	20
Emails Opened	10
Links Clicked	10
Data Submitted	5
Emails Reported	5

5. PHISHING RISK ASSESSMENT

Step 8: Risk Assessment Table

The campaign results were evaluated using the number of recorded events divided by the number of targeted recipients.

Formula:

Rate = (Number of recorded events / Total targeted recipients) × 100

The following table presents the actual campaign findings.

Metric	Result	Calculated Rate	Risk Interpretation	Control Implication
Emails Sent	20/20	100%	All targeted test emails were successfully sent, indicating successful campaign execution.	SMTP configuration and email delivery process were functional.
Emails Opened	10/20	50%	Half of the recipients opened the simulated phishing email, indicating engagement with the message.	Security awareness training should emphasize identifying suspicious senders, unexpected requests and email content.

Links Clicked	10/20	50%	Half of the targeted recipients clicked the simulated phishing link, indicating potential susceptibility to phishing attempts.	Employees require further training on URL verification and identifying suspicious links. Email filtering controls should also be reviewed.
Data Submitted	5/20	25%	A quarter of the targeted recipients proceeded to submit information through the simulated landing page, indicating a significant credential-compromise risk.	Enforce Multi-Factor Authentication (MFA), strengthen credential protection and provide targeted phishing awareness training.
Emails Reported	5/20	25%	Only a quarter of the targeted recipients reported the simulated phishing email, suggesting limited use of phishing-reporting procedures.	Improve phishing-reporting procedures and educate employees on how and when to report suspicious emails.

Risk Assessment Interpretation

The simulation indicates potential weaknesses in the organization's human-related security controls. Although all 20 test emails were successfully sent, 50% of recipients opened the emails, while another 50% clicked the simulated phishing links.

More importantly, 25% of the targeted recipients submitted information through the simulated landing page. This suggests a significant risk of credential compromise if similar behaviour occurs during an actual phishing attack.

Additionally, only 25% of recipients reported the simulated phishing email, highlighting the need to improve employee awareness and establish effective phishing-reporting procedures.

These findings demonstrate the importance of combining employee awareness training, technical security controls and continuous monitoring to reduce phishing-related risks.

6. EXECUTIVE SUMMARY AND RECOMMENDATIONS

To: CISO, Head of HR and Executive Management
From: GRC Audit Team
Date: 4 November 2026
Subject: Results of Controlled Phishing Simulation and Human Risk Assessment

6.1 Executive Summary

A controlled phishing simulation was conducted using GoPhish to evaluate organizational exposure to social engineering attacks and assess the effectiveness of existing security awareness and email security controls.

The exercise involved configuring GoPhish on Kali Linux, integrating Mailtrap as an SMTP testing service, creating a simulated phishing email and landing page, and conducting a controlled campaign against a test group.

The campaign results showed that 50% of recipients opened the simulated phishing email, 50% clicked the embedded link, and 25% proceeded to submit information through the simulated landing page. Furthermore, only 25% reported the suspicious email.

These findings highlight potential weaknesses in phishing awareness, link verification and incident-reporting behaviour. The credential-submission rate is particularly concerning because similar behaviour during an actual attack could expose organizational accounts and sensitive information to unauthorized access.

6.2 Key Findings

The major findings were:

1. Email Open Rate – 50%

Half of the targeted recipients opened the simulated phishing email. This demonstrates engagement with the message and highlights the importance of educating employees on identifying suspicious email characteristics.

2. Link Click-Through Rate – 50%

Half of the targeted recipients clicked the embedded link. This indicates potential weaknesses in users' ability to identify suspicious URLs and verify the legitimacy of links before interacting with them.

3. Credential Submission Rate – 25%

A quarter of the targeted recipients submitted information through the simulated landing page. This is a significant finding because similar behaviour in a real attack could result in credential compromise and unauthorized system access.

4. Email Reporting Rate – 25%

Only a quarter of the recipients reported the simulated phishing email. This suggests that employees may not be sufficiently familiar with the organization's phishing-reporting procedures.

6.3 Risk Analysis

- **Unauthorized Access:** Attackers may use stolen credentials to gain access to corporate systems and applications.
- **Data Breaches:** Compromised accounts may expose confidential organizational information.
- **Financial Loss:** Successful phishing attacks may result in fraudulent transactions and financial damage.
- **Reputational Damage:** Security incidents may reduce customer confidence and damage organizational reputation.
- **Regulatory Consequences:** Failure to adequately protect sensitive information may result in regulatory penalties and compliance issues.

6.4 Recommendations

1. Implement Multi-Factor Authentication (MFA)

Organizations should enforce MFA across critical systems and applications. This provides an additional layer of protection even when user credentials are compromised.

2. Strengthen Security Awareness Training

Organizations should move beyond annual compliance training by introducing continuous, practical and engaging security awareness programmes.

Employees should receive training on:

- Recognizing suspicious emails.
- Identifying malicious links and attachments.
- Verifying unexpected requests.
- Protecting login credentials.
- Reporting suspected phishing attempts.

3. Conduct Regular Phishing Simulations

Organizations should conduct authorized phishing simulations periodically to assess employee awareness and measure improvements over time.

Results should be used to identify employees or departments requiring additional training.

4. Strengthen Email Security Controls

Organizations should implement and maintain appropriate email security controls, including:

- Spam and phishing filters.
- Sender Policy Framework (SPF).
- DomainKeys Identified Mail (DKIM).
- Domain-based Message Authentication, Reporting and Conformance (DMARC).
- Malicious URL and attachment detection.

5. Establish Clear Phishing Reporting Procedures

Employees should have a simple and accessible process for reporting suspicious emails to the IT or information security team.

Reported incidents should be investigated, documented and addressed promptly.

6. Review and Communicate Security Policies

The Acceptable Use Policy and Information Security Policy should clearly define employee responsibilities regarding suspicious emails, credential protection and incident reporting.

Security policies should not end at management approval or board meetings. Employees must be made aware of these policies, understand their responsibilities and consistently follow the established requirements.

Management should also ensure that employees receive regular policy updates and that compliance is monitored.

7. Monitor and Measure Improvement

Management should establish measurable security awareness indicators, including:

- Phishing simulation click rate.
- Credential-submission rate.
- Phishing reporting rate.
- Employee training completion rate.
- Repeat susceptibility rate.

These indicators should be reviewed periodically to determine whether security controls and training programmes are improving.

7. LAB CONCLUSION

This practical exercise demonstrated how social engineering and phishing simulations can be used to assess human-related security risks.

The installation and configuration of GoPhish, integration with Mailtrap, creation of a simulated email template and landing page, and execution of a controlled campaign provided practical exposure to phishing simulation tools.

From a Governance, Risk and Compliance (GRC) perspective, the exercise highlighted the importance of identifying risks, evaluating security controls, documenting findings and communicating recommendations to management.

It also reinforced that cybersecurity is not solely a technical responsibility. Employees must understand security policies, recognize potential threats and follow established procedures.

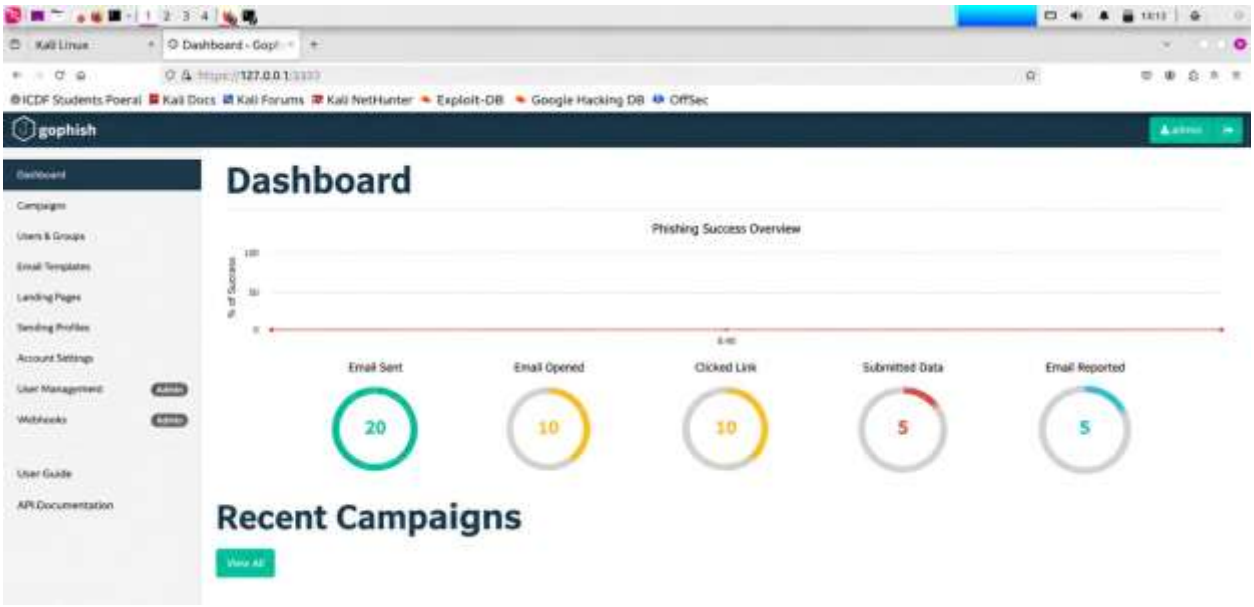
Ultimately, an effective GRC programme should combine technical safeguards, employee awareness, management oversight and continuous monitoring to reduce organizational risk.

8. DELIVERABLES

The following items are provided as evidence of the practical exercise:

Deliverable 1: GoPhish Campaign Results Screenshot

The actual GoPhish campaign results screenshot showing the email-sending event and campaign metrics.



Deliverable 2: Phishing Risk Assessment Table

The completed risk assessment table documenting the campaign results, calculated rates, risk interpretations and control implications.

Deliverable 3: Executive Summary and Recommendations

The executive report outlining the campaign findings, potential organizational risks and recommended security improvements.